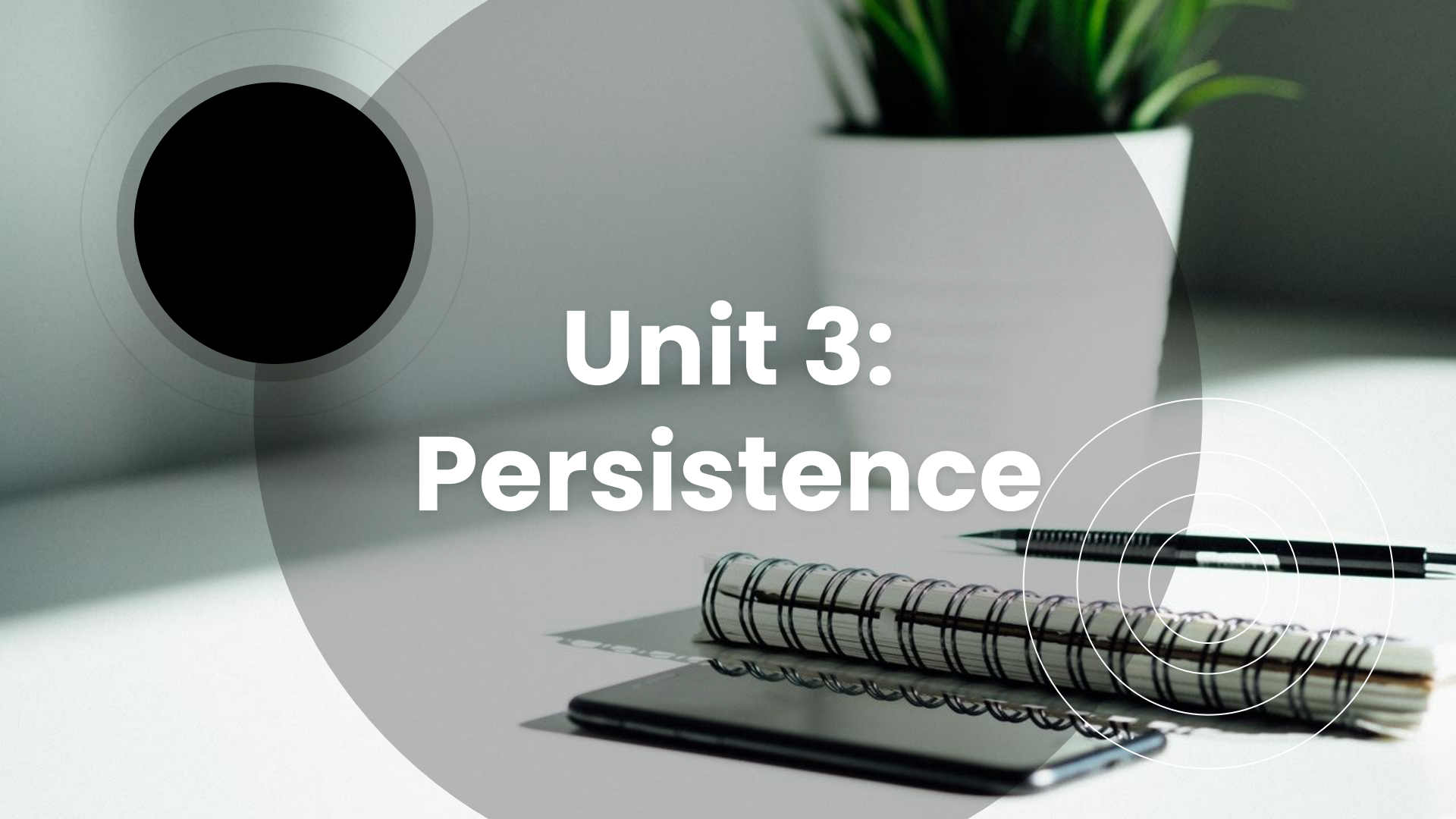
Unit 3: Persistence



What is persistence?

Malware behavior can be grouped in two ways

- absolutely destroy the system
- stay on the system, hide from everything, and covertly extract information

Persistence is an act of the latter behavior

Persistent malware will try to hide itself and achieve persistence to continue even after a reboot



An xkcd comic on malware persistence

Comic Explanation

Windows Registry was an old-fashioned way of malware to hide onto the system

```
HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run
```

Anything in here would execute whenever a specific user logged in (whichever user the malware was run on)

Comic Explanation

If it somehow gains admin privileges, it can edit its way into the HKLM registry tree

```
HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
```

In this case, the malware will run whenever the system boots

Nowadays

Malware has different ways of embedding itself

Antimalware covers common spots for you

- Malwarebytes
- Avast
- many, many other free antimalware for you to try

> It’s a great thing that cybersecurity’s importance is better recognized these days. People now understand the need for antimalware.

– Me

Chapter 1: Task Scheduler

Annoying as %$#@#

What are they?

They run specific tasks at a specific schedule

Purposes:

- Maintenance
- Updates
- Security
- Malicious intent

So basically...

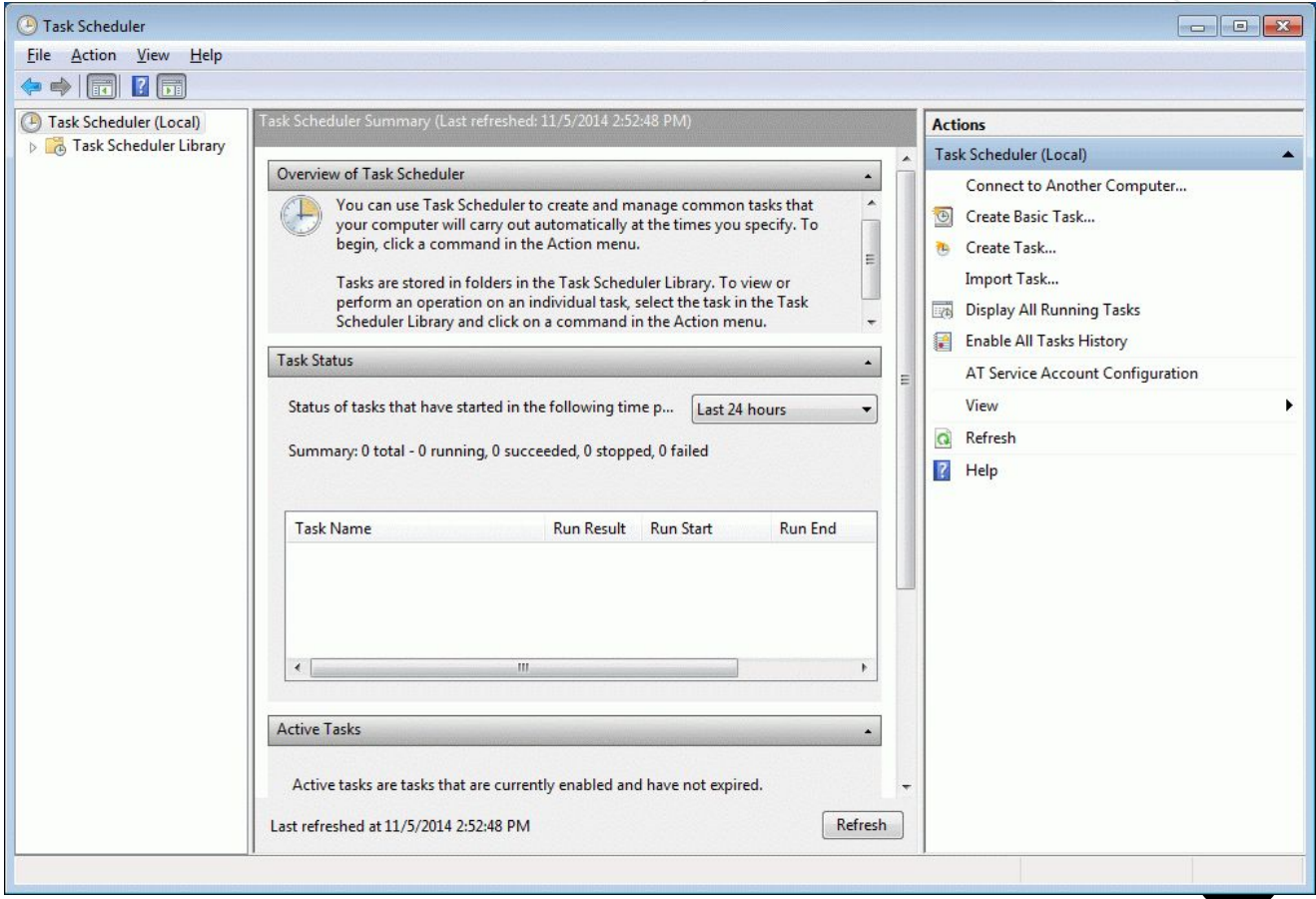
- Run tasks at specific schedules can mean
  - Upon an event
    - User login
    - Program opened
    - etc
  - After x amount of time
  - etc
- Why are we learning about them?
  - Usually only for system maintenance
  - Hackers can take advantage of them

A Peek at Task Scheduler

Search “task scheduler”

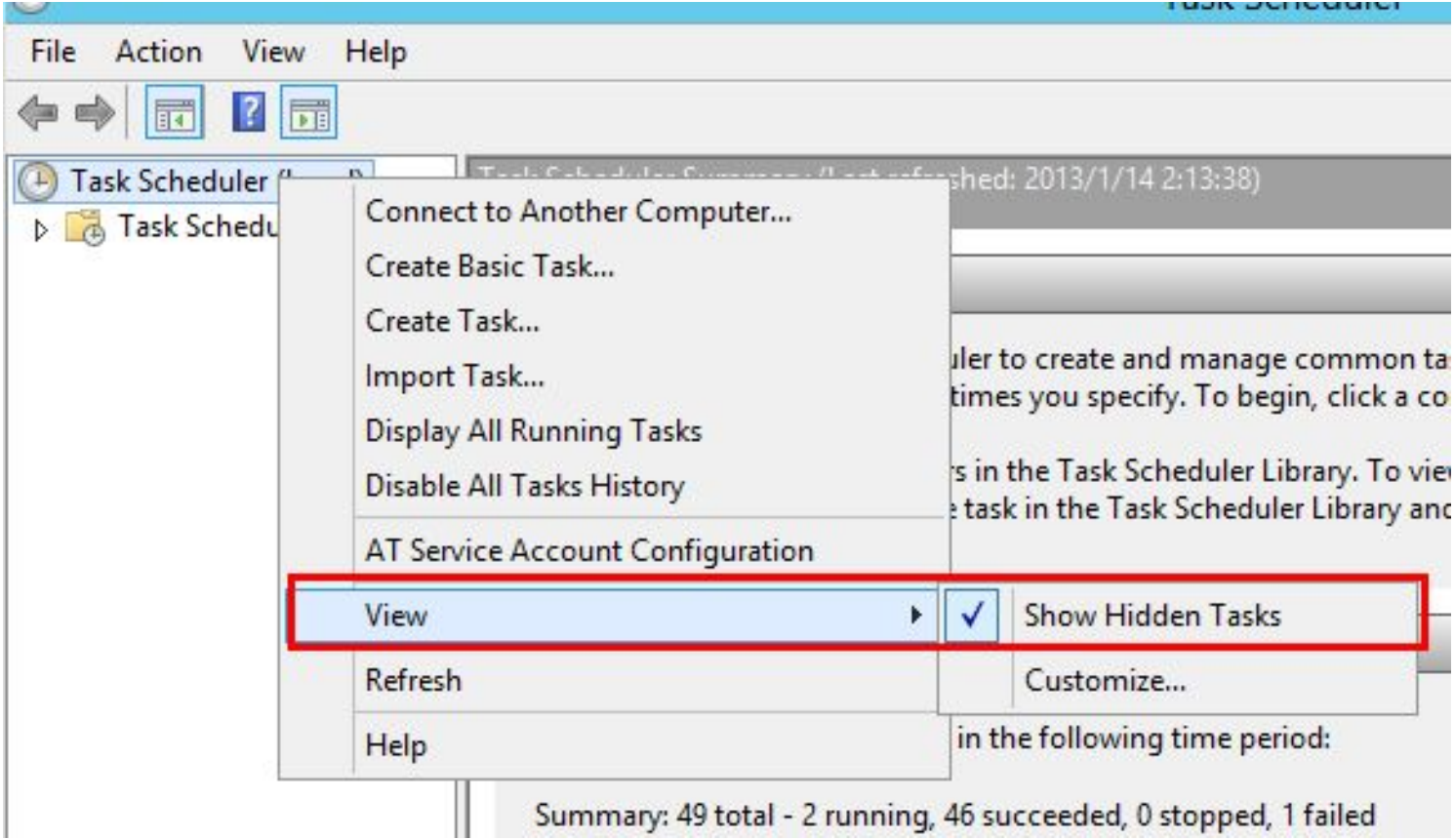
or

Win+R: taskschd.msc



What does it do?

- “Task Status” Section does not work as it says it does so ignore it
- “Active Window” shows tasks that have been started before/ones that are waiting to be started
- You can create tasks on the right side through a helpful wizard
- On the right side it also allows you to “Show Hidden Tasks” under the “View” menu
    - Make sure this is checked



Showing hidden tasks

Finding Bad Tasks

What to do?

- First identify a bad task
  - This requires your “CyberPatriot deduction skills”
- Recommendation
  - See if you can find an obviously malicious task
  - Configure everything. When you restart your computer, look for any changes to your settings (or the points you gained)- if you find a change, this MAY be indicative of a scheduled task
  - There could be other reasons why, but in these next examples we can assume that this is the case

How do I find a malicious task?

Your main method of searching through the many innocent tasks is by looking at the **name**, the **trigger**, and the **action** upon trigger of each active task

You can also try out third-party software, just make sure they are trustworthy

Summary: look for malicious tasks

Manually

- Look at the attributes for each tasks
  - This includes name, trigger type, and action performed
- While this is a pain, this is the simplest method to do so

Other ways

- Sysinternals has Autoruns, a GUI that allows you to view all tasks in a better way
- If you prefer scripting, know that:
  - Tasks are stored in `C:\Windows\System32\tasks`
  - Tasks are XML files that run Task.Actions.Exec.Command

Chapter 2 Section 1: GPEDIT

Although not technically malware persistence, technically a form of persistence

GPEDIT

GPEDIT is like LSP but on steroids

Capable of preventing users from changing settings - grayed out boxes

There are literally A TON OF SETTINGS

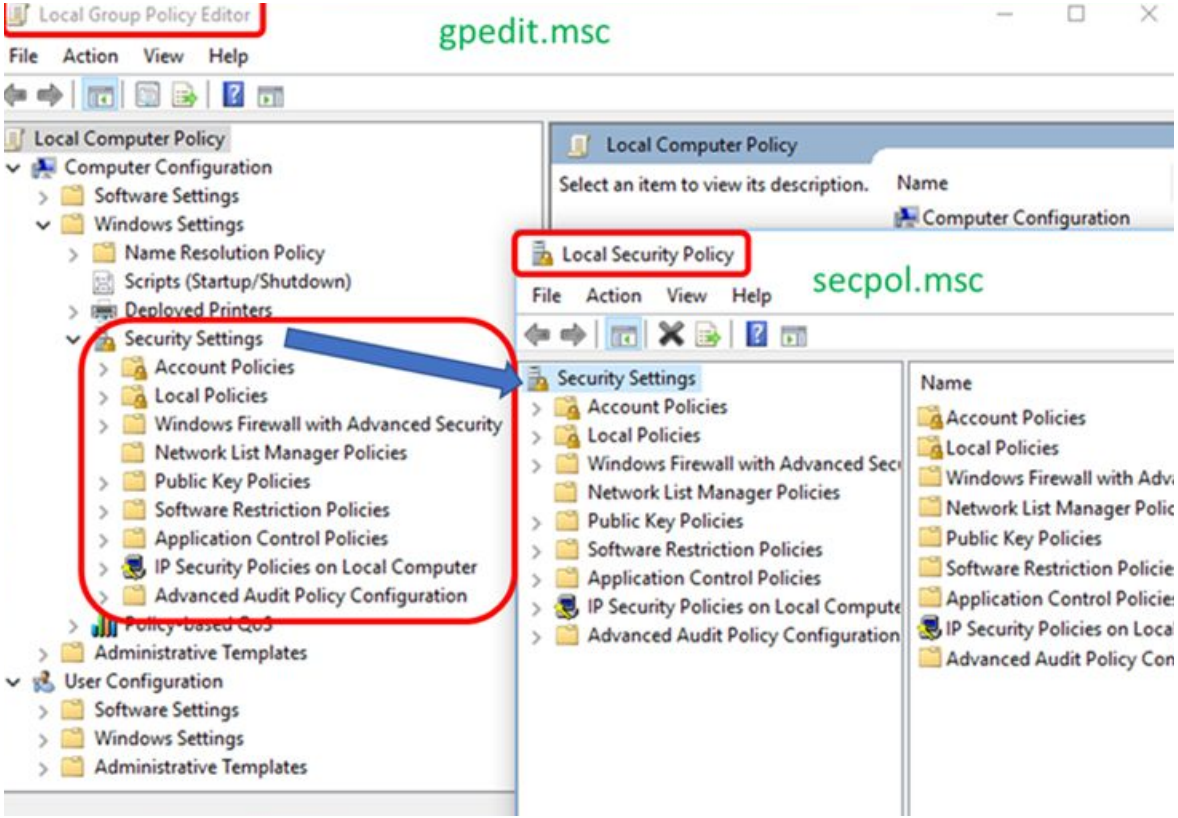
- Most of these settings are not security related
- Most of the security settings can be easily determined through common sense

Group Policy Editor

The Group Policy Editor is the built in tool for Windows to manage your computer's policies

Win+R: gpedit.msc

You'll note that LSP is a part of the overall Group Policy - you can enforce LSP here so it cannot be changed



Some examples

- Computer Configuration > Administrative Templates > Windows Components > Autoplay Policies
  - "Turn off Autoplay" - Enabled for All Drives
- Computer Configuration > Administrative Templates > Windows Components > Remote Desktop Services > Remote Desktop Session Host > Connections
  - "Allow users to connect remotely by using Remote Desktop Services" - Disabled
  - // * IF REMOTE IS NOT REQUIRED, else Enabled

More examples

- User Configuration > Administrative Templates > Control Panel > Personalization
  - "Enable screen saver" - Enabled
- User Configuration > Administrative Templates > Control Panel > Personalization
  - "Password protect the screen saver" - Enabled
- Computer Configuration > Administrative Templates > Network > Network Connections > Windows Firewall
  - For all profiles, set "Windows Firewall: Protect all network connections" to Enabled

Even more examples

- Computer Configuration > Administrative Templates > Windows Components > Remote Desktop Services > Remote Desktop Session Host > Security
  - "Require secure RPC communication" - Enabled
  - "Require user authentication for remote connections by using Network Level Authentication" - Enabled
- Computer Configuration > Windows Settings > Security Settings
  - GPEDIT LSP

Woah wait that's too much Where can I go for more settings?

https://www.stigviewer.com/

View settings rated on a scale of severity

https://gpsearch.azurewebsites.net/

The search engine for GPEDIT settings

Or just google "gpedit hardening forum" or something similar

After changes...

Don’t forget to either restart your computer OR run “gpupdate /force” (as a command)

This will ensure that GPEDIT changes are made to the computer

Chapter 2 Section 2: LGPO

LGPO tool
Can save you fifteen percent
It's a bad haiku

LGPO (Local Group Policy Object)

LGPO is a tool for importing and exporting group policy settings

Search online and download

LGPO is a command-line utility (you run it like a command)

LGPO Usage Details

- Download LGPO here: https://www.microsoft.com/en-us/download/details.aspx?id=55319
  - If you drag LGPO.exe to your C:/Windows/System32/ folder, you can use it from cmd
    - System32 is included in Window's PATH variable
    - PATH specifies where to looks for executables
    - That's why you can run "cmd" without specifying the full path

Making a Backup

Open cmd with admin privileges and go to the directory that holds LGPO.exe

Type: lgpo /b <path where u want to save the policy>

Example: lgpo /b “%USERPROFILE%\Desktop”

This will make the backup folder on your current user’s desktop

Applying your backup

Open cmd with admin privileges and go to the directory with LGPO.exe and your backup

Type: LGPO /g <path of the folder with the name>

Review: what should you do after changes?

FInish by running: gpupdate /force

This will force an update of GPEDIT and enforce the settings on the computer

thx

If you have any questions about using LGPO, ask one of the instructors in class.

A classroom post on LGPO will be posted some time this week

Chapter 3: Event Logs

I can see everything you do, Jon
Do not resist

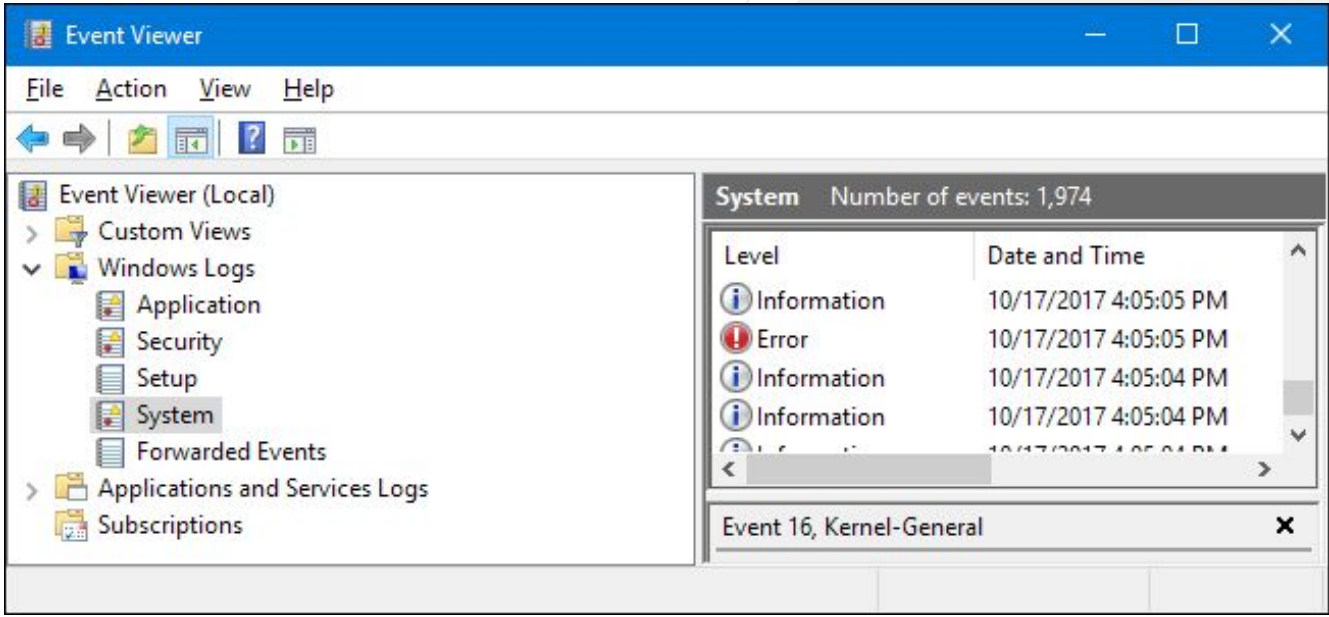
What is event viewer?

The event viewer is a tool to view all event logs recorded in the Windows Event Log. You can view event logs on a local or remote machine

Audit policies need to be set, and Windows Event Log service needs to be enabled

Where is event viewer?

Access event viewer either by searching or by Win+R (eventvwr.msc)



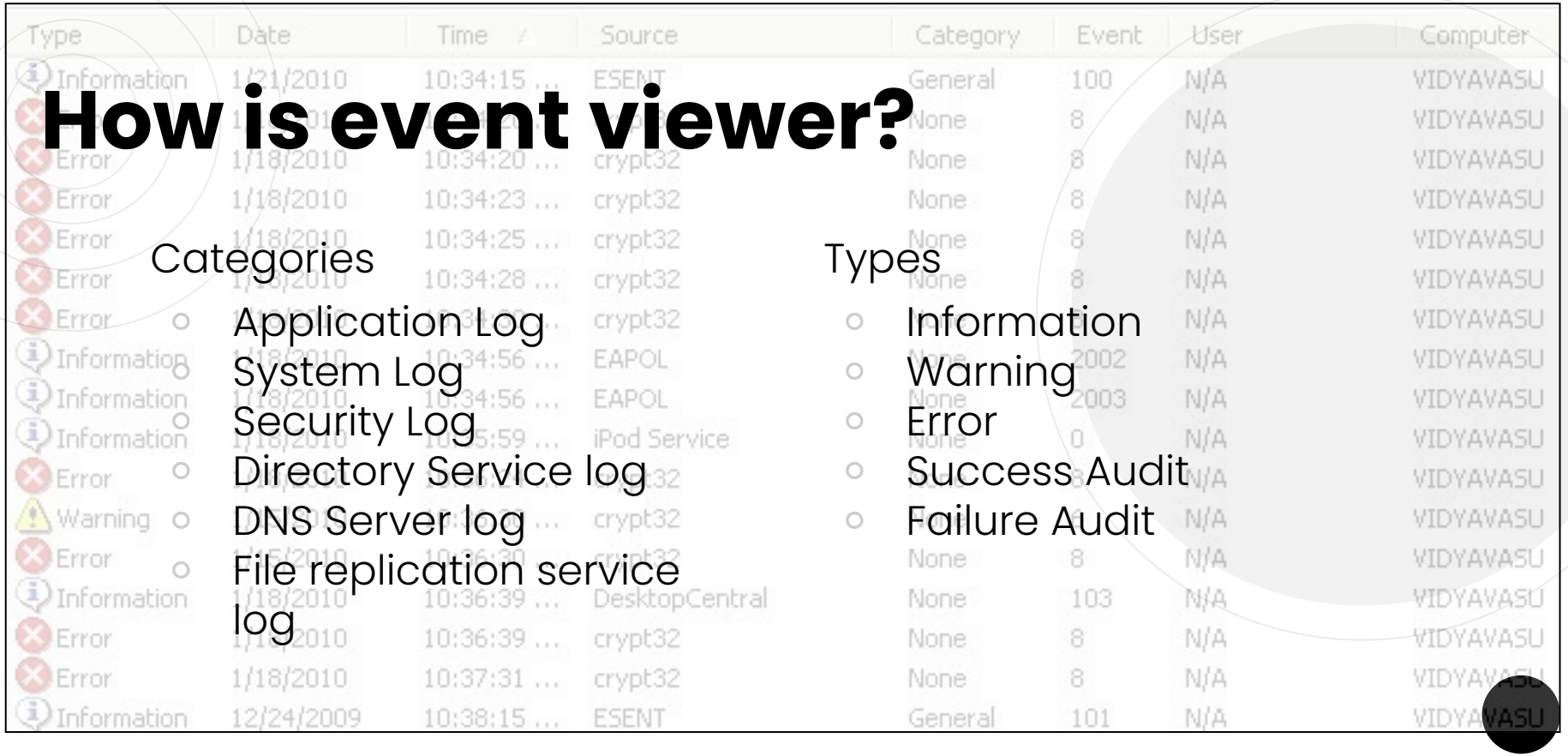
How is event viewer?

Categories

- Application Log
- System Log
- Security Log
- Directory Service log
- DNS Server log
- File replication service log

Types

- Information
- Warning
- Error
- Success Audit
- Failure Audit



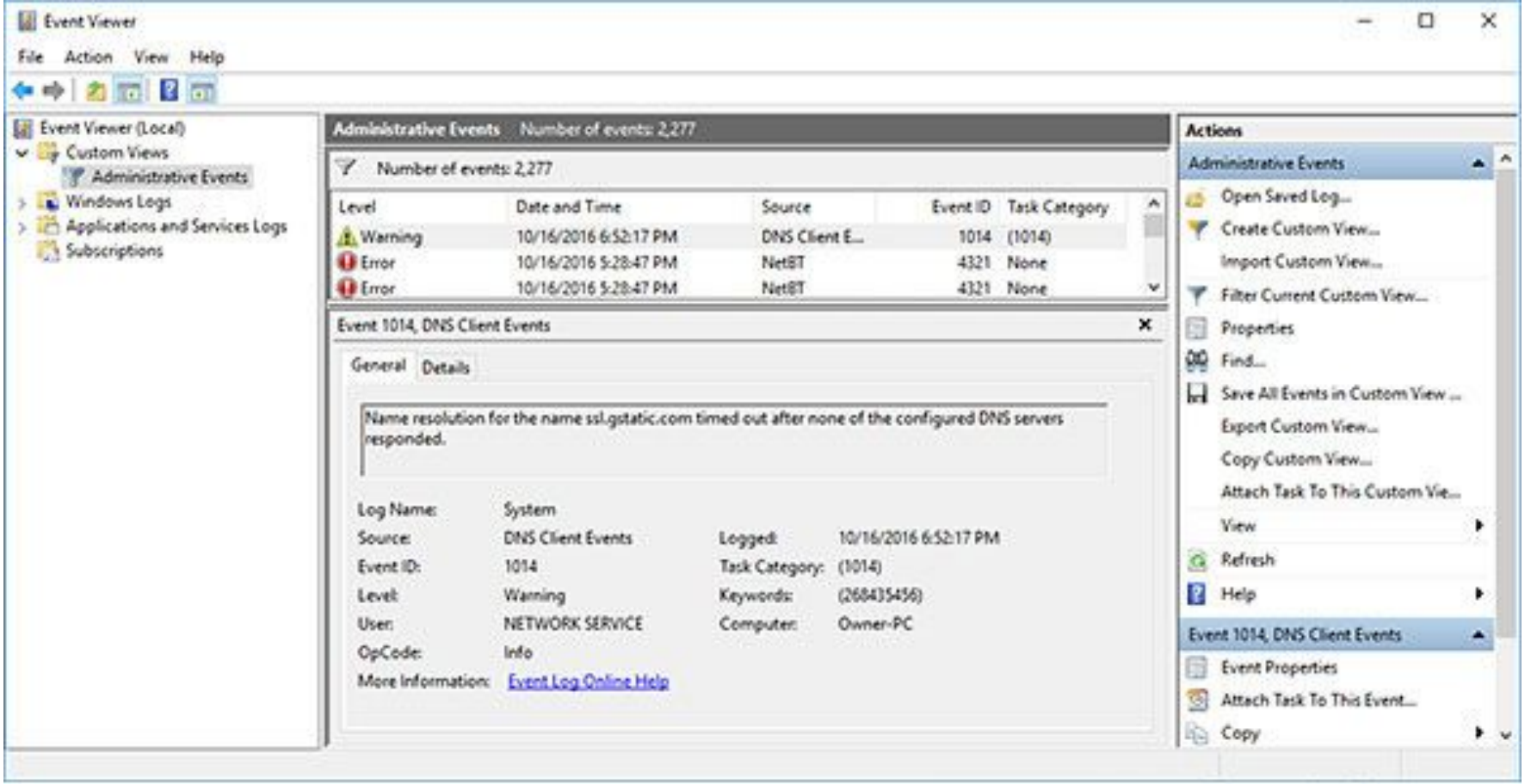
Why is event viewer?

Aggregated logs
Audit policy > event log

How to read

Each log will have their own headers that provide information on certain aspects during the time of the log, in addition to the information being recorded

- date
- the user logged in
- the source
- etc.



ComputerHope.com

Metadata of logs

Event IDs

Identify a type of event - search online for ID #

Some of the few of the many IDs:

- 4723,4724 - Change Password
- 4720,4726,4738,4781 - Delete, Change Accounts
- 4608,4609 - Startup, Shutdown
- 4613 - Clear Security Log
- 4616 - Change System Time
- 4617 - Unable to Log
- 4714,4705 - Privilege assigned or removed
- 4708,4714 - Change audit policy
- 4717,4718 - System access granted or removed
- 4739 - Change domain policy
- 16390 - Administrator account lockout
- 4727-4730,4731-4734,4735,4737,4784,4755-4758 - Group changes
- 4624,4636,4803,4801 - Account logons
- 4625,4626,4627,4628,4630,4635,4649,4740,4771,4772,4777 - Logon failures (KEYWORD: Audit Failure)
- 4672 - Admin account logons
- 4698 - Schedule new job
- 4656 - Access refused to object
- 3004,3005 - Windows defender finds something
- 4664 - Create hard link to audited file
- 865 - Software restriction triggered
- 1000 - Application Error (Event Level: CHECKMARK "Error")
- 1002 - Application Hang (Event Level: CHECKMARK "Error")
- 1037 - Protected Mode violation
- 7031 - Service terminated unexpectedly
- 4697 - Install a Service
- 4663 - Access audited file

Chapter 4: Backdoors

Spooky scary doors
Who knew doors were dangerous

Backdoors?

Methods of connecting to computer, bypassing all security policies in place

Intended for troubleshooting but can be used maliciously

Types

Passive/dormant

- Harder to find, harder to trigger unless time or event based

Active

- Easier to find, but deadlier since it’s already listening for a connection

Searching for them

Antimalware is generally great at finding them (not 100% of the time, however!)

If passive/dormant, your only hope is antimalware programs or manually searching and patience

If active, you can check ports and task manager for suspicious processes

Finding active backdoors

netstat -aon

lists all network connections and the process ID (PID) as well as the IP address and port numbers in numerical order

netstat -anbo

needs admin cmd

does netstat -aon but also lists processes' names

task manager

view Details tab for a sketchy process name or description

Backdoor schools of thought

Stay on the computer as long as possible

Two methods

One is to pretend to be harmless

- Random name like “ComputerHelper.exe”
- Windows exe name similarity like “system.exe”
  - The true Windows process is System (capitalized, without a .exe)

Backdoor schools of thought

Another is to hide self as best as possible - redirects computer functions to itself to obtain information

These types of backdoors are also called rootkits, and they are very hard to find

They can hide from task manager, netstat, and registry